CYBERSHIELD AI - OPERATIONAL WORKFLOW & INCIDENT RUNBOOK

Standard Operating Procedures (SOP) | Incident Response Matrix | Report Generation Guide

1. System Overview & Daily Platform Operations

CyberShield AI is an enterprise cybersecurity monitoring platform connecting central cloud orchestration (FastAPI on Render + Neon PostgreSQL) with on-premise monitoring agents. Daily operations require three active layers: the Backend API server, the Frontend single-page application, and at least one local Endpoint Monitoring Agent.

Daily Startup & Operation Flow

Component	Execution Command	Default Port / URL	Expected Status Probe
1. Backend API	uvicorn app.main:app --port 8000	http://localhost:8000	GET /health -> status: healthy
2. Neon Database	alembic upgrade head	Neon Port 5432 (Pooler)	GET /health/db -> connected
3. Frontend UI	npm run dev	http://localhost:5173	HTTP 200 Login Screen rendered
4. Network Agent	python main.py	HTTPS to Backend /api/v1	ONLINE badge in Agents table (30s)

User Roles & Operational Responsibilities

* Administrator (admin@cybershield.ai): Full platform control. Issues agent enrollment tokens, manages users, edits system configuration settings, revokes compromised sensors, and reviews immutable compliance audit logs.
* Security Analyst (analyst@cybershield.ai): Daily triage operator. Runs discovery scans, initiates vulnerability probes, acknowledges and resolves security alerts, chats with Local AI assistant, and generates executive reports.
* Viewer (viewer@cybershield.ai): Read-only auditor. Views metrics, device lists, CVEs, and compliance summaries.

2. Generating Compliance & Executive Reports

CyberShield AI features an integrated PDF and CSV reporting pipeline built directly into the backend using fpdf2. Reports summarize real security telemetry, device inventories, vulnerability matrices, and incident response timelines.

Step-by-Step: How to Generate a Report in the UI

1. In the left navigation sidebar, click 'Reports' (Restricted to Administrator and Security Analyst roles).
2. Click the '+ Generate Report' button in the upper-right corner.
3. Select the desired Report Type from the options modal:
   - Security Overview Report: Executive summary of overall organizational security posture, fleet asset counts, agent connectivity health, risk score distribution, and alert volume.
   - Vulnerability Assessment Report: In-depth technical catalog of all identified CVEs, affected host IP addresses, listening software service banners, and severity CVSS scores.
   - Incident & Alert Audit Report: Comprehensive chronological record of all triggered alarms, attacker source IPs, analyst status transitions, response timelines, and resolution notes.
4. Choose the Reporting Period: Select Start Date and End Date (e.g., past 30 days or quarterly range).
5. Click 'Generate Report'. The backend compiles the telemetry and marks the record as READY.
6. In the Report Archive table, click 'PDF' to open/download a print-ready document or 'CSV' for SIEM data ingestion.

3. Incident Response Matrix: What to Do When What Happens

This section serves as the definitive Standard Operating Procedure (SOP) and runbook for security operators. Follow these prescribed action trees when alarms trigger or abnormal events occur.

Trigger / Condition	Underlying Event Cause	Platform Automated Action	Required Operator Action
Agent Status: OFFLINE	Sensor missed 3 heartbeats (90s) due to network drop or crash	Marks status OFFLINE in DB; stops assigning scans to sensor	Verify sensor power, inspect agent/.env BACKEND_UR
Alert: brute_force	5+ failed logins from same source IP within a 10-minute window	Creates Alert, assigns Risk Score=40, sends in-app notification	Acknowledge alert -> Check Log Management -> Block IP a
Alert: port_scan	Host scan detected 10+ open ports on a single device	Creates Alert, assigns Risk Score=20, increases device risk factor	Verify if authorized vulnerability audit. If not, isolate host on
Alert: suspicious_login	Successful login from IP that had 3+ failures in previous hour	Creates Alert, assigns Risk Score=20, notifies admins	High-risk credential stuffing! Force password reset; revoke a
Alert: malware_indicator	Network traffic source IP matches Threat Intelligence IOC list	Creates Alert, assigns Risk Score=40, records AuditLog	Immediately isolate endpoint; trace process initiating outbou
CVE Finding: Critical	Agent banner probe matched known RCE CVE (e.g., Log4Shell)	Registers vulnerability; adds +30 to device risk score	Click 'Explain with AI' -> Apply recommended vendor securi
Device Risk: Critical	Combined high CVEs, active alerts, and port exposures	Escalates device into Critical Risk Band on dashboard	Prioritize remediation of Critical CVEs and disable exposed

4. Detailed Playbooks: Step-by-Step Incident Workflows

Playbook A: Brute Force Authentication Attack Response

When an incident alert with alert_type='brute_force' appears in the top navigation bell:
Step 1 - Triage & Acknowledge: Click the bell icon or navigate to 'Alerts'. Click the incident title to open details. Click the yellow 'Acknowledge' button. This stops alert duplication and notifies other team members you own the triage.
Step 2 - AI Root Cause Assessment: Click the 'Explain with AI' button. The Local Security Explanation Engine will immediately parse the incident telemetry, identify the MITRE ATT&CK technique (T1110.001 - Password Guessing), and suggest immediate firewall isolation.
Step 3 - Investigate Targeted Users: Go to 'Log Management' and filter by source IP matching the alert. Check which corporate usernames were targeted. Check if any 'login_success' event occurred after the failures.
Step 4 - Mitigation: Add the attacker's IP to your perimeter firewall blocklist or VPN gateway null-route.
Step 5 - Resolution: Return to the Alert page. Click the green 'Resolve' button and type your incident notes: 'Attacker IP blocked at perimeter firewall. Target accounts verified uncompromised.' An immutable AlertEvent and AuditLog are saved.

Playbook B: Critical Vulnerability Remediation Workflow

When an automated scan discovers a critical vulnerability (e.g. CVE-2021-41773 Apache Path Traversal):
Step 1 - Review Vulnerability Details: Go to 'Vulnerability Mgmt'. Filter by Severity: 'Critical'.
Step 2 - Query AI Remediation: Click 'Explain with AI'. LocalRuleAI provides the specific minimum software version required to patch the flaw (e.g. upgrade Apache HTTP Server to 2.4.51 or higher) and transient configuration workarounds.
Step 3 - Patch & Rescan: Deploy the security update to the host. In 'Devices', trigger 'Run Discovery Scan' to confirm the service version banner has updated and the vulnerability is closed.

5. Platform Resilience, Security Architecture & FAQ

Security Architecture Safeguards

1. Rate Limiting Protection: The POST /auth/login endpoint is shielded by SlowAPI at 10 requests/minute per IP. Rapid unauthorized attempts are rejected with HTTP 429 Too Many Requests.
2. Strict Organization Boundaries: Every resource (device, alert, scan, setting) is scoped by organization_id. Users and agents cannot view or alter telemetry belonging to another tenant.
3. LocalRuleAI Privacy: The AI assistant runs 100% on the backend server. Zero customer data, IP addresses, or vulnerability parameters are transmitted across external cloud AI APIs.

Frequently Asked Operational Questions

Q: What happens if the backend server restarts while an agent is running?
A: The agent contains an exponential backoff retry loop and an in-memory offline queue. It buffers heartbeats and retries connecting every 30 seconds for up to 10 attempts (5 minutes) before gracefully reporting status.

Q: Why does the device risk score change after resolving an alert?
A: The CyberShield multi-factor risk engine recalculates device risk dynamically. Resolved alerts no longer contribute penalty points (+20 for brute force, +15 for suspicious login), immediately lowering the host's risk band.

Q: How can I export audit logs for external compliance reviews (SOC 2, ISO 27001)?
A: Log in as Administrator. Navigate to 'Settings' -> 'Audit Logs' or 'Reports'. Generate an 'Incident & Alert Audit Report' and download the CSV format for direct import into SIEM or compliance spreadsheets.